

Data Classification Framework

Company A
Ministry of Health - Kingdom of Saudi Arabia

Document Control

Field	Details
Document Title	Data Classification Framework
Document ID	CLS-FRM-001
Version	3.5
Effective Date	February 15, 2024
Last Review Date	February 1, 2024
Next Review Date	February 15, 2025
Classification	INTERNAL
Owner	Chief Data Officer (CDO)
Approver	Data Governance Committee (DGC)
Related NDMO Controls	Domain 7: Data Classification - Controls 7.1-7.12

Version History

Version	Date	Author	Changes
1.0	January 2021	Data Governance Team	Initial framework
2.0	March 2022	Dr. Yasser Al-Najjar (CDO)	Added PDPL alignment, 4-tier model
3.0	September 2023	Data Governance Team	Added Microsoft Purview integration
3.5	February 2024	Dr. Yasser Al-Najjar	Added handling matrix, re-classification procedure

Table of Contents

- 1. [Introduction](#1-introduction)
- 2. [Classification Principles](#2-classification-principles)
- 3. [Classification Levels](#3-classification-levels)

4. [Classification Criteria](#4-classification-criteria)
5. [Classification Process](#5-classification-process)
6. [Labeling Requirements](#6-labeling-requirements)
7. [Handling Matrix](#7-handling-matrix)
8. [Re-Classification Procedures](#8-re-classification-procedures)
9. [Roles and Responsibilities](#9-roles-and-responsibilities)
10. [Compliance and Monitoring](#10-compliance-and-monitoring)
11. [Appendices](#11-appendices)

1. Introduction

1.1 Purpose

This Data Classification Framework establishes standardized categories for organizing Company A's information assets based on:

- Sensitivity of the data
- Business impact if data is compromised (confidentiality, integrity, availability)
- Regulatory requirements (PDPL, NDMO, NCA)

1.2 Scope

Applies To:

- All data created, collected, processed, stored, or transmitted by Company A
- All employees, contractors, and third parties handling Company A data
- All systems, applications, and storage media containing Company A data

Data Types Covered:

- Patient health records (Epic EHR)
- Employee personnel files (SAP HR)
- Financial records (Oracle EBS)
- Operational data (bed capacity, inventory)
- Research data (clinical trials, studies)
- Communication records (email, documents)

1.3 Regulatory Alignment

Regulation	Requirement	Framework Compliance
PDPL Article 8	Personal data must be classified and protected bas	■ 4-tier classification with CONFIDENTIAL level fo
NDMO Domain 7	Data classification framework required with docume	■ Framework v3.5 addresses all 12 NDMO controls
NCA ECC	Information must be classified according to govern	■ Aligned with Saudi government 4-tier model
ISO 27001 A.8.2	Information classification policy required	■ Framework serves as classification policy

1.4 Definitions

Term	Definition
Data Classification	Process of categorizing data based on sensitivity
Sensitivity	Degree to which data requires protection from unau
Data Owner	Business function accountable for data accuracy, q
Data Custodian	IT function responsible for technical implementati
Labeling	Process of marking data with its classification le
Handling	Rules governing how data may be stored, transmitt

2. Classification Principles

2.1 Core Principles

Principle 1: Risk-Based Classification

Classify data based on the potential harm if confidentiality, integrity, or availability is compromised. Higher risk = higher classification = stronger controls.

Principle 2: Default to Higher Classification

When uncertain, classify data at the higher (more restrictive) level. It is easier to downgrade classification than to recover from a breach of under-protected data.

Principle 3: Classification by Content, Not Container

A document's classification is determined by its most sensitive content, not by the system or location where it is stored.

Example: An Excel file containing 100 rows of aggregated statistics (INTERNAL) and 1 row with a patient name (CONFIDENTIAL) must be classified as CONFIDENTIAL.

Principle 4: Inheritance of Classification

When data is derived, copied, or aggregated from classified sources, the derivative inherits the highest classification of its sources.

Example: Report combining PUBLIC bed occupancy data with CONFIDENTIAL patient satisfaction survey responses is classified as CONFIDENTIAL.

Principle 5: Lifetime Classification

Data retains its classification throughout its lifecycle (creation, storage, use, sharing, archival, disposal) unless formally re-classified.

2.2 Business Impact Assessment

Classification is based on potential impact across five dimensions:

Impact Dimension	Description	Assessment Questions
Patient Safety	Impact on patient health or clinical care	Could disclosure harm patients physically or psych
Privacy	Impact on individual privacy rights	Does data identify individuals? Could it cause emb
Financial	Monetary loss (fines, lawsuits, revenue)	What is the potential financial loss from breach?
Reputational	Damage to Company A's public image	Would disclosure make headlines? Erode patient/pub
Operational	Disruption to business processes	Would unavailability disrupt healthcare delivery o

3. Classification Levels

3.1 Four-Tier Classification Model

Company A uses a 4-tier classification system aligned with Saudi government standards:

Level	Name	Color	Impact if Compromised	% of Data
1	PUBLIC	■ Green	None	5%
2	INTERNAL	■ Blue	Low (operational disruption)	60%
3	CONFIDENTIAL	■ Orange	High (privacy breach, reputation)	30%
4	SECRET	■ Red	Critical (national harm)	5%

3.2 Level 1: PUBLIC (Green ■)

Definition: Information intentionally approved for public release. Disclosure causes no harm to Company A, patients, or employees.

Characteristics:

- Data has been formally approved for public release by Communications Director
- Data is already published on Company A website or press releases
- No legal, contractual, or policy restrictions on disclosure

Examples:

Category	Examples
Marketing	Press releases, public website content, annual rep
Contact Info	Hospital locations, phone numbers, visiting hours
Health Info	General health awareness materials (e.g., "How to
Policies	Public-facing Privacy Policy, Patient Rights Chart

Handling Summary:

- No restrictions on storage, transmission, or sharing
- May be posted on public websites, social media
- No encryption required

3.3 Level 2: INTERNAL (Blue ■)

Definition: Information intended for Company A employees only. Disclosure outside Company A would cause low to moderate harm (operational disruption, minor embarrassment).

Characteristics:

- Not intended for public release but not highly sensitive
- Available to all or most Company A employees
- Unauthorized disclosure would cause inconvenience but not significant harm

Examples:

Category	Examples
Policies	Internal policies, procedures, guidelines
Operational	Meeting minutes, project plans, org charts, traini
Communication	Internal memos, newsletters, all-staff emails
Statistics	Aggregated operational data (no personal identifie

Handling Summary:

- Access limited to Company A employees
- May be stored on internal SharePoint, network drives
- Do not email to personal (non-Company A) email addresses
- No encryption required but recommended for external transmission

3.4 Level 3: CONFIDENTIAL (Orange ■)

Definition: Sensitive information that must be protected. Disclosure would cause significant harm (privacy violations, regulatory fines, legal liability, reputational damage).

Characteristics:

- Contains personal data (names, IDs, health records, financial info)
- Contains commercially sensitive information (contracts, pricing, strategies)
- Subject to legal or regulatory protection (PDPL, contractual confidentiality)
- Access restricted to employees with business need-to-know

Examples:

Category	Examples
Personal Data	Patient names, medical records, diagnoses, lab res
Employee Data	Salaries, performance reviews, disciplinary record
Financial	Budget details, vendor contract pricing, unpublish
Legal	Contracts, legal opinions, settlement agreements
Strategic	Business strategies (before Board approval), M&A d

Handling Summary:

- Access restricted to authorized users with business need
- Encryption required at rest and in transit
- MFA required for access
- Do NOT email to personal email addresses
- Store only on approved systems (encrypted network drives, SharePoint)
- Physical documents: Lock in secure cabinet, shred when no longer needed

3.5 Level 4: SECRET (Red ■)

Definition: Extremely sensitive information requiring highest level of protection. Disclosure would cause critical harm (national security implications, severe legal liability, danger to individuals).

Characteristics:

- Affects national security or critical infrastructure
- Could endanger lives if disclosed
- Subject to government classification requirements
- Access restricted to <10 specifically authorized individuals

Examples:

Category	Examples
VIP Data	Medical records of government officials, royal fam
National Security	Pandemic response plans classified by MOH, critica
Investigation	Active fraud investigations, whistleblower identit
Cybersecurity	Unpatched vulnerabilities, penetration test result

Handling Summary:

- Access restricted to specifically named individuals approved by CEO
- Strong encryption required (AES-256) at rest and in transit
- Air-gapped systems where feasible
- All access logged and audited
- Physical documents: Numbered pages, secure safe storage, CCTV surveillance
- Do NOT email even on Company A email (use encrypted file transfer)

4. Classification Criteria

4.1 Decision Matrix

Use the following matrix to determine classification level:

Criteria	PUBLIC	INTERNAL	CONFIDENTIAL	SECRET
Contains personal identifiers (names, IDs)	No	No	Yes	Yes (VIPs)
Contains health/medical data	No	No	Yes	Yes (VIPs)
Contains financial details (salaries, pricing)	No	No	Yes	No
Approved for public release	Yes	No	No	No
Available to all employees	N/A	Yes	No	No
Need-to-know restriction	No	No	Yes	Yes
Regulatory protection (PDPL, contract)	No	No	Yes	Yes
National security implication	No	No	No	Yes
Could endanger individuals	No	No	No	Yes

4.2 Classification Decision Tree

START: What is this data?

■

■■■■ Is it approved for public release?

■ ■■■■ YES → PUBLIC ■

■ ■■■■ NO → Continue

■

■■■■ Does it contain personal identifiers (names, IDs, medical records)?

■ ■■■■ YES → Is this a VIP (government official, celebrity)?

■ ■■■■ YES → SECRET ■

■ ■■■■ NO → CONFIDENTIAL ■

■ ■■■■ NO → Continue

■

■■■■ Does it contain sensitive business information (financials, contracts, strategies)?

■ ■■■■ YES → CONFIDENTIAL ■

■ ■■■■ NO → Continue

■

■■■■ Is it intended only for Company A employees?

■ ■■■■ YES → INTERNAL ■

■ ■■■■ NO → Consider if PUBLIC ■ is appropriate

■

■■■ When in doubt → Classify UP (more restrictive)

4.3 Examples by Data Type

Data Type	Classification	Rationale
Company A website content	PUBLIC ■	Already published for public
Internal policy documents	INTERNAL ■	For employees only, low harm if leaked
Employee salary spreadsheet	CONFIDENTIAL ■	Personal financial data, privacy impact
Patient appointment list (with names)	CONFIDENTIAL ■	Personal health data, PDPL protected
Patient diagnosis records	CONFIDENTIAL ■	Sensitive health data
Minister's medical record	SECRET ■	VIP, national security implication
Unpatched security vulnerability	SECRET ■	Could enable cyberattack
Aggregated bed occupancy stats	INTERNAL ■	No personal identifiers
Press release draft (approved)	PUBLIC ■	Intended for public release

5. Classification Process

5.1 Responsibilities in Classification Process

Role	Responsibility
Data Owner	Determine classification based on content; review
Data Creator	Apply initial classification when creating data
Data Custodian (IT)	Implement technical controls matching classificati
All Employees	Respect classification labels; report misclassific
Data Governance Team	Provide guidance; audit classification accuracy

5.2 Classification Workflow

Step 1: Creation

When data is created (document written, database table designed, report generated), the creator must:

1. Assess the sensitivity using Section 4 criteria
2. Determine the appropriate classification level
3. Apply the label immediately (before saving or sharing)

Step 2: Validation

For high-sensitivity data (CONFIDENTIAL, SECRET), the Data Owner must:

1. Review and validate the classification

2. Document the classification decision (rationale)
3. Approve handling procedures

Step 3: Implementation

The Data Custodian (IT) must:

1. Apply technical controls matching the classification (encryption, access controls)
2. Configure systems to enforce handling rules
3. Monitor for policy violations

Step 4: Ongoing Review

The Data Owner must:

1. Review classification annually (minimum)
2. Re-classify if sensitivity changes
3. Document any classification changes

6. Labeling Requirements

6.1 Electronic Labeling (Microsoft Purview)

Company A uses Microsoft Purview Information Protection (formerly AIP) for electronic labeling.

Configuration:

- Sensitivity Labels: PUBLIC, INTERNAL, CONFIDENTIAL, SECRET
- Automatic Labeling: Purview suggests labels based on content (e.g., detects National ID patterns → suggests CONFIDENTIAL)
- Mandatory Labeling: Users cannot save/send documents without selecting a label

Label Appearance:

- Email Subject: Prepended with `[CLASSIFICATION]` (e.g., `[CONFIDENTIAL] Patient List`)
- Document Header/Footer: Colored watermark with classification name
- Visual Marking:
 - PUBLIC: Green watermark
 - INTERNAL: Blue watermark
 - CONFIDENTIAL: Orange watermark
 - SECRET: Red watermark

6.2 Physical Labeling

For paper documents and physical media:

Classification	Label/Stamp	Placement
PUBLIC	Green stamp: "PUBLIC"	Top-right corner of first page
INTERNAL	Blue stamp: "INTERNAL - COMPANY A ONLY"	Top-right corner of each page

CONFIDENTIAL	Orange stamp: "CONFIDENTIAL - DO NOT SHARE"	Top-right corner of each page
SECRET	Red stamp: "SECRET - AUTHORIZED ACCESS ONLY"	Top-right corner of each page + numbered pages

Stamp Availability: Classification stamps available in each department's office supply cabinet.

6.3 System/Database Labeling

For databases and systems, classification is recorded in the Data Catalog (Collibra):

Asset Type	Labeling Method
Database/Schema	Collibra asset tagged with classification attribut
Table/View	Column-level classification in Collibra (e.g., "Pa
Application	System security classification recorded in CMDB
Cloud Storage	S3 buckets/Blob containers tagged with classificat

7. Handling Matrix

7.1 Handling Rules by Classification

Handling Aspect	PUBLIC	INTERNAL	CONFIDENTIAL	SECRET
Access Control	None	Company A employees	Need-to-know (role-based)	Named individuals (CEO approved)
Authentication	None	Single Sign-On (SSO)	SSO + MFA	SSO + MFA + Biometric
Encryption at Rest	Optional	Optional	Required (AES-256)	Required (AES-256)
Encryption in Transit	Optional	Recommended (TLS)	Required (TLS 1.3)	Required (TLS 1.3 + IPsec)
Email	Unrestricted	Company A email only	Company A email + encrypted	Encrypted file transfer only
Personal Email	Allowed	Not allowed	Not allowed	Not allowed
USB/External Media	Allowed	Company devices only	Encrypted USB only	Not allowed
Cloud Storage	Unrestricted	Approved cloud only	Approved cloud + encryption	Not allowed (on-premise only)
Printing	Unrestricted	Unrestricted	Secure print (PIN release)	Numbered pages, logged
Physical Storage	Unrestricted	Desk drawer	Locked cabinet	Safe with access log
Disposal (Paper)	Recycle bin	Shred (standard)	Cross-cut shred	Cross-cut shred + witness
Disposal (Electronic)	Standard delete	Standard delete	Secure wipe (3-pass)	DoD 5220.22-M (7-pass)
Sharing External	Unrestricted	NDA required	DPA + DPO approval	CEO approval + NDA
Access Logging	Optional	Optional	Required	Required + quarterly audit

7.2 Transmission Controls

Transmission Method	PUBLIC	INTERNAL	CONFIDENTIAL	SECRET
Company A email	■	■	■ (encrypted)	■
Personal email (Gmail)	■	■	■	■
SharePoint (internal)	■	■	■ (with access controls)	■
OneDrive (sync)	■	■	■■ (IT-approved devices only)	■
SFTP (secure file transfer)	■	■	■	■
USB drive (personal)	■	■	■	■
USB drive (encrypted, Company-issued)	■	■	■	■
WhatsApp	■	■	■	■
Fax	■	■■ (verify recipient)	■■ (DPO approval)	■
Verbal (public spaces)	■	■	■	■
Verbal (private room)	■	■	■	■ (swept room)

8. Re-Classification Procedures

8.1 When to Re-Classify

Data classification may change over time. Re-classification is required when:

Scenario	Direction	Example
Public Announcement	Downgrade	SECRET merger plan → PUBLIC after press release
Regulatory Change	Upgrade	INTERNAL data becomes PDPL-protected → CONFIDENTIAL
Time Passage	Downgrade	CONFIDENTIAL 10-year-old salary data → INTERNAL (historical)
Aggregation	Downgrade	CONFIDENTIAL individual records → INTERNAL aggregated data
De-identification	Downgrade	CONFIDENTIAL patient data → INTERNAL anonymized data
Discovery	Upgrade	INTERNAL document found to contain patient names → CONFIDENTIAL

8.2 Re-Classification Process

Step 1: Request

- Data Owner or Data Steward submits Re-Classification Request Form (Appendix A)
- Specify: Current classification, proposed classification, justification

Step 2: Review

- Data Governance Team reviews request within 5 business days
- Validates justification against classification criteria

Step 3: Approval

Re-Classification Type	Approver
Downgrade to PUBLIC	Communications Director
Downgrade to INTERNAL	Data Owner + DPO
Upgrade to CONFIDENTIAL	Data Owner + DPO
Upgrade to SECRET	CEO
Downgrade from SECRET	CEO

Step 4: Implementation

- Update labels (electronic and physical)
- Update Data Catalog entry
- Adjust access controls and technical controls
- Notify affected users

8.3 Annual Review Cycle

All classifications must be reviewed annually by Data Owners:

Review Activity	Frequency	Owner	Deadline
CONFIDENTIAL data review	Annual	Data Owners	January 31
SECRET data review	Annual	CDO + CEO	January 31
Data Catalog classification audit	Annual	Data Governance	February 28

2024 Review Results:

- Total datasets reviewed: 245
- Re-classifications approved: 12 (5%)
- 8 downgrades (CONFIDENTIAL → INTERNAL for historic data)
- 4 upgrades (INTERNAL → CONFIDENTIAL for newly identified personal data)

9. Roles and Responsibilities

9.1 RACI Matrix

Activity	Data Owner	Data Custodian	Data Creator	DPO	DGC
Determine initial classification	I	I	R	C	I

Validate classification	A	I	I	C	I
Apply labels	C	R	R	I	I
Implement technical controls		R	I	C	A
Review classification annually	A	I	I	C	A
Approve re-classification	A	I	I	C	C
Audit classification accuracy		C	I	R	A
Investigate misclassification	C	R	C	A	I

Legend: R = Responsible, A = Accountable, C = Consulted, I = Informed

9.2 Key Roles

- Chief Data Officer (CDO) - Dr. Yasser Al-Najjar
- Framework owner and executive sponsor
 - Approves SECRET classification changes
 - Chairs Data Governance Committee
- Data Protection Officer (DPO) - Noura Al-Mansour
- Ensures PDPL compliance in classification
 - Reviews CONFIDENTIAL data handling
 - Investigates classification incidents
- Data Governance Committee (DGC)
- Approves framework updates
 - Resolves classification disputes
 - Reviews annual classification audit
- Data Owners (Department Heads)
- Accountable for data classification accuracy in their domain
 - Conduct annual classification reviews
 - Approve re-classification requests

10. Compliance and Monitoring

10.1 Compliance Metrics

Metric	Target	Q4 2024 Actual	Status
% of datasets with assigned classification	100%	98.5%	■■ (gap remediation in progress)
% of CONFIDENTIAL data encrypted at rest	100%	100%	■
% of documents with sensitivity labels	95%	97%	■

Classification audit findings (high severity)	0	■
Annual classification review completion	100%	■

10.2 Monitoring and Enforcement

Automated Monitoring:

- Varonis DatAlert: Monitors for CONFIDENTIAL data in unauthorized locations
- Microsoft Purview: Alerts when unlabeled documents created
- Splunk SIEM: Logs access to CONFIDENTIAL and SECRET data

Manual Audits:

- Quarterly Spot Checks: Data Governance samples 50 documents/month for labeling compliance
- Annual Classification Audit: Full review of Data Catalog classification accuracy

Enforcement:

- First Offense (minor): Verbal warning + remedial training
- Second Offense: Written warning
- Third Offense or Major Violation: Disciplinary action (up to termination)

10.3 Incident Reporting

Misclassification Incident: Data found to be classified at incorrect level

Reporting Process:

1. Discoverer reports to Data Governance Team: datagovernance@company.gov.sa
2. Data Governance investigates within 48 hours
3. If under-classified, immediate upgrade and control implementation
4. Root cause analysis and corrective action
5. Incident logged in classification incident register

2024 Incidents:

- Total misclassification incidents: 5
- Under-classified (INTERNAL → CONFIDENTIAL): 3
- Over-classified (CONFIDENTIAL → INTERNAL): 2
- Impact: None (all caught before external disclosure)

11. Appendices

Appendix A: Re-Classification Request Form

Form ID: CLS-FORM-001

Field	Value
Requestor Name	_____
Department	_____
Date	_____
Data Asset Name	_____
Data Catalog ID	_____
Current Classification	■ PUBLIC ■ INTERNAL ■ CONFIDENTIAL ■ SECRET
Proposed Classification	■ PUBLIC ■ INTERNAL ■ CONFIDENTIAL ■ SECRET
Justification	_____
Approver (Data Owner)	_____
Approver (DPO/CEO)	_____

Submit to: datagovernance@companya.gov.sa

Appendix B: Quick Reference Card

Classification at a Glance:

Level	Color	Ask Yourself	Example
PUBLIC ■	Green	"Can this be on our website?"	Press releases
INTERNAL ■	Blue	"For employees only?"	Policies, memos
CONFIDENTIAL ■	Orange	"Does it have names/IDs/salaries?"	Patient records
SECRET ■	Red	"VIP? National security?"	Minister's records

When in Doubt: Classify UP (more restrictive) or ask datagovernance@companya.gov.sa

Appendix C: Classification Label Templates

Email Label (Outlook):

- Click "Sensitivity" → Select level → Label auto-applies to subject line

Document Watermark (Word):

- Click "Sensitivity" → Select level → Colored watermark appears on all pages

Physical Stamp:

- Location: Office supply cabinet in each department
- Colors: Green, Blue, Orange, Red

Document Approval:

Prepared By:

Data Governance Team

Date: February 1, 2024

Reviewed By:

Noura Al-Mansour, Data Protection Officer

Date: February 10, 2024

Approved By:

Data Governance Committee (DGC)

Chair: Dr. Yasser Al-Najjar, Chief Data Officer

Date: February 15, 2024

Next Review Date: February 15, 2025

Document Location: SharePoint → Data Governance → Frameworks → Data_Classification_Framework_v3.5

END OF DOCUMENT